PUBLIC KEY INFRASTRUCTURE

S06: Certificate Transparency (CT) & Ma Trận Tấn Công AD CS

Nguyen An Khuong, *CSE-HCMUT*
ORCID: 0000-0002-9910-6387 · Email: nakhuong@hcmut.edu.vn

Ho Chi Minh City University of Technology (HCMUT), VNU-HCM
Faculty of Computer Science and Engineering
Teaching Assistant: Mr. Nguyen Huu Hoang Huy (LinkedIn Profile)

Session 6 of 9 · ATHK 512 (KMA CHAT4P, HK261)
Class: Sat 07/11/2026 · 13h30–18h30
Standards: IETF RFC 6962, SpecterOps ESC1–ESC8, Sigma Rules

1. Tổng quan & Lộ trình Buổi S06

Lộ Trình Học Phần (Buổi 6/9)

S01: Architecture, Trust & Threat Models	S02: X.509, ASN.1 & Path Validation	S03: CA Lifecycle & ACME Protocol
S04: Revocation (CRL/OCSP) & Hardware HSM	S05: TLS 1.3 & mTLS Zero Trust Gateway	**S06: Certificate Transparency (CT) Logs & Merkle Tree**
S07: PQC Migration NIST FIPS 203/204	S08: Enterprise AD CS Attack & Defense	S09: Capstone Defense & Audit Synthesis

Buổi học kết hợp giữa cơ chế giám sát toàn cầu (Certificate Transparency) và kỹ thuật tấn công leo thang đặc quyền doanh nghiệp nghiêm trọng nhất hiện nay (AD CS Exploitation).

Chuẩn Đầu Ra Buổi Học S06 (Learning Objectives)

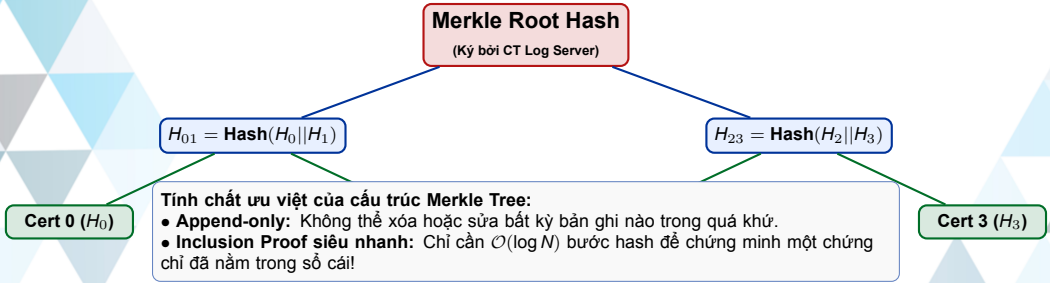
Sau buổi học S06, học viên làm chủ các năng lực:

1. **Phân tích** kiến trúc cây Merkle Tree và bằng chứng thành viên (Inclusion Proof) trong RFC 6962.
2. **Giải mã** cấu trúc Signed Certificate Timestamp (SCT) nhúng trong chứng chỉ X.509.
3. **Khai thác** và **phòng ngự** các kỹ thuật tấn công AD CS kinh điển: ESC1, ESC8.
4. **Xây dựng** luật giám sát Sigma Rules phát hiện hành vi lạm dụng chứng chỉ trên Active Directory.

Nguyên Tắc Minh Bạch Tuyệt Đối. ”Ánh sáng mặt trời là chất khử trùng tốt nhất.” Certificate Transparency biến việc phát hành chứng chỉ số từ hoạt động đóng kín thành sổ cái công khai mà toàn cầu có thể cùng giám sát.

2. Sổ Cái Công Khai Certificate Transparency (RFC 6962)

Kiến Trúc Cây Merkle Tree Trong CT Logs



Signed Certificate Timestamp (SCT) & Quy Chuẩn Trình Duyệt

- **Cơ chế cấp phát SCT:** Khi nhận yêu cầu cấp chứng chỉ, CA gửi Pre-certificate lên ít nhất 2–3 máy chủ CT Logs độc lập (Google, Cloudflare, DigiCert).
- CT Log trả về biên nhận có chữ ký số gọi là **SCT (Signed Certificate Timestamp)**, cam kết chứng chỉ sẽ được đưa vào sổ cái trong vòng 24 giờ.
- CA nhúng SCT này vào phần mở rộng X.509 v3 của chứng chỉ chính thức.

Yêu Cầu Tuân Thủ Tuyệt Đối Của Trình Duyệt Web

Kể từ năm 2018, Google Chrome, Apple Safari và Mozilla Firefox **từ chối kết nối ngay lập tức** nếu chứng chỉ SSL thiếu bằng chứng SCT hợp lệ!

3. Ma trận Tấn công Active Directory CS (AD CS)

Khai Thác Lỗ Hổng Mẫu Chứng Chỉ AD CS: ESC1

Nghiên cứu đột phá của SpecterOps (2021) chỉ ra kỹ thuật chiếm quyền Domain Controller:

Cấu hình sai trên Mẫu (Template):

- Cấp cờ `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`.
- Cấp quyền EKU `Client Authentication`.
- Cho phép nhóm `Authenticated Users` xin cấp chứng chỉ.

Chuỗi khai thác của Hacker:

- Dùng công cụ `Certipy` yêu cầu cấp chứng chỉ nhưng điền tên chủ thể là `Administrator`.
- Nhận chứng chỉ máy tính mang danh tính Quản trị viên tối cao.
- Dùng kỹ thuật PKINIT Kerberos đổi vé TGT và chiếm toàn bộ mạng!

Phòng Ngự Kỹ Thuật (Đề tài Đồ án Nhóm 2). Vô hiệu hóa ngay cờ `ENROLLEE_SUPPLIES_SUBJECT` trên các mẫu chứng chỉ cấp quyền đăng nhập người dùng.

Tấn Công NTLM Relay Tới Cổng Web Enrollment: ESC8

Beyond · Critical Pitfall to Avoid. **Điểm yếu cố hữu của giao diện web AD CS (`/certsrv`):** Mặc định cổng này hỗ trợ xác thực NTLM và không bật tính năng chống chuyển tiếp ký số (NTLM Signing / EPA), đồng thời thường chạy trên HTTP không có mã hóa TLS!

- Kẻ tấn công kích hoạt tấn công `PetitPotam` hoặc ép máy Domain Controller xác thực NTLM sang máy của hacker.
- Hacker chuyển tiếp gói xác thực NTLM này tới cổng web của CA (`/certsrv`).
- CA chấp nhận xác thực và cấp chứng chỉ máy chủ hợp lệ cho Domain Controller.
- Hacker dùng chứng chỉ vừa nhận để mạo danh Domain Controller, chiếm đoạt toàn bộ mật khẩu trong cơ sở dữ liệu `ntds.dit`!

Chiến Lược Phòng Ngự & Giám Sát Bằng Sigma Rules

Quy Tắc Hardening Hạ Tầng AD CS Doanh Nghiệp

1. Gỡ bỏ hoàn toàn dịch vụ Web Enrollment (`/certsrv`) nếu không thực sự sử dụng.
2. Bắt buộc bật Extended Protection for Authentication (EPA) và SSL trên IIS.
3. Giám sát Windows Event Log ID `4886` (Yêu cầu cấp) và `4887` (Đã cấp chứng chỉ).

```
# Kiem tra cac template AD CS de bi tan cong bang Certipy
certipy find -u user@kma.local -p Password123 -dc-ip 192.168.1.10 -vulnerable
```

Bài Tập Tự Kiểm Tra Buổi S06

Câu Hỏi Thẩm Định Năng Lực.

1. **Câu 1:** Tại sao hacker sở hữu chứng chỉ giả mạo có chữ ký của CA hợp lệ vẫn bị phát hiện nếu chứng chỉ đó không được ghi vào CT Logs?
   Giải đáp: Vì trình duyệt hiện đại bắt buộc phải có biên nhận SCT từ các CT Log công khai. Không có SCT, trình duyệt sẽ báo lỗi an ninh ngay lập tức và chặn truy cập!
2. **Câu 2:** Trong cuộc tấn công ESC8, biện pháp khắc phục triệt để nhất ở mức cấu hình máy chủ web IIS là gì?
   Giải đáp: Bật tính năng Extended Protection for Authentication (EPA) sang chế độ Required và kích hoạt cơ chế gán kênh truyền (Channel Binding) trên IIS.